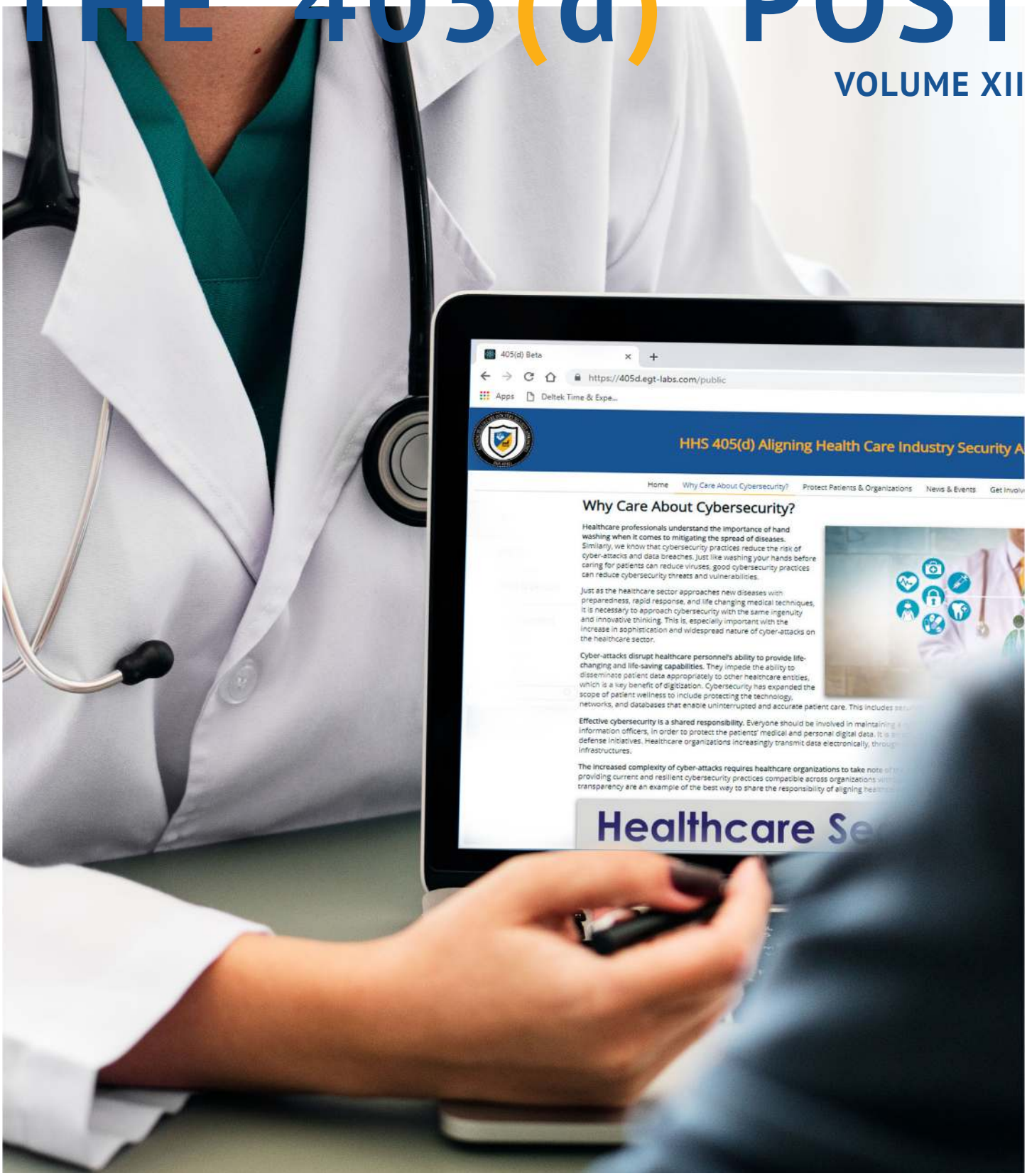
THE 405(d) POST

VOLUME XII



HHS 405(d)
Aligning Health Care
Industry Security Approaches

Rural Health and Cybersecurity

By Guy McAllister, 405(d) Task Group Member

Rural America. We conjure up images of farmland, ponds, creeks, and friendly neighbors. These are all valid images; however, rural America also has seen economic plight and poor population health. This leaves many of the rural hospitals and clinics trying their best to serve an underserved segment of our population. Although the government stepped in to provide assistance with legislations such as The Hill-Burton Act of 1946, which calls for loans to construct hospitals in cities and towns across the country, many of those hospitals are still struggling to meet the expenses of operating a modern hospital. They struggle with staffing issues, financial strains, and IT inequities that put them at risk every day. The COVID-19 pandemic brought additional challenges to these healthcare organizations as well.

On a personal note, I have a passion for rural hospitals and physician clinics having lived in the rural South most of my life and having served as a Chief Information Officer (CIO). There, in a small-town setting, it was ingrained in my thinking that healthcare is local. I now live in North Florida, where rural is still a way of life and rural hospitals seek to accomplish their mission every day.

There are two areas of concern to examine for the rural healthcare landscape that are IT related: cybersecurity threats and adequately trained cybersecurity IT staff. These two areas of concern have been put on a collision course since the COVID-19 pandemic started impacting the country in early 2020.

Cyber threats have escalated at an alarming rate in 2020. In a recent New Jersey Business Magazine article, Dave Wreski, CEO of Guardian Digital, Inc., notes that "small and medium-sized businesses are an especially popular target among ransomware operators, who recognize that these companies often lack the cybersecurity resources and expertise required to repel an attack." This observation by Wreski points to this collision: increased ransomware attacks and limited or non-trained cybersecurity resources to help protect against the threat. This is where today's rural hospital system finds itself. These hospitals and clinics cannot afford the financial impact of shutting services down due to inaccessible records while servers are down, or worse, paying the ransom.

"This is where today's rural hospital system finds itself. These hospitals and clinics cannot afford the financial impact of shutting services down due to inaccessible records while servers are down, or worse, paying the ransom."

According to the American Hospital Association, "some 57 million rural Americans depend on their hospital as an important source of their area's economic and social fabric."

The American Hospital Association published an article in 2019, "Ransomware Attacks on Hospitals Have Changed." In summary, the author states, "Hospitals may feel powerless to stop cyberattacks and their motivations, but that is far from the case. Hospitals can improve their cyber defense and resilience by appreciating the new foes and risk levels they face, updating cybersecurity and enterprise risk management practices to correlate to the elevated threat level, and communicating the nature and seriousness of ransomware threats to staff, business partners, public policy organizations, law enforcement agencies and legislators." For the rural hospitals to survive cyber attacks, they must update their **cybersecurity** and **enterprise risk management.** That may involve culture change around email and phishing awareness, or it may involve greater detailed security risk assessments. These are necessary improvements, but only if there are staff trained in cybersecurity available and affordable to them.

Employees in apprenticeship programs become highly skilled and high performing with a 94% retention rate.

For this reason, the apprenticeship model is being applied for technology and cybersecurity workforce development because this form of workforce development builds talent in a way that fits an organization's specific needs. Apprenticeship is the most employer-driven form of workforce development and it has been shown to retain high-skilled employees. According to the Department of Labor, **employees in apprenticeship programs become highly skilled and high performing with a 94% retention rate.**

For the next two years, there is a national program called Tech Quest Apprenticeship (TQA) that can be used to train and up-skill staff to meet the nation's growing technology and digital security demands. TQA is designed to create new positions and accelerate the expansion of existing IT and IT-related registered apprenticeship programs in communities across the country. This program is funded by a $12 million grant from the U.S. Department of Labor, Employment, and Training Administration. Led by Clark University—and partnering with a national consortium of workforce development boards, employers, higher education institutions, training providers, and other strategic partners—TQA is providing technical support, subject matter expertise, and subsidized training to 5,000 people who have what it takes to support individual business technology needs.

The TQA program is on example of how we can reach underserved areas of our sector, like the rural healthcare organizations. Even though we cannot prevent bad actors around the world from engaging in cyber attacks against us, we can, and must, raise the bar in defending against those attacks by training individuals and equipping them in the field of cybersecurity so they can be employed in all hospitals, including those in rural America, possibly where these TQA apprentices live. **Why? Because healthcare is local!**

HICP in the Spotlight

September is National Preparedness Month!

National Preparedness Month is an observance each September to raise awareness about the importance of preparing for disasters and emergencies that could happen at any time. The 2021 theme is “Prepare to Protect. Preparing for disasters is protecting everyone you love.” This year the 405(d) Program will celebrate National Preparedness Month by emphasizing the importance of cybersecurity readiness! Cyber attacks in the Healthcare and Public Health (HPH) sector can affect the ones you love, therefore it is important to remember that cyber preparedness = Patient Safety.

How can 405(d) Help you stay Cyber Prepared? We’re glad you asked! See below for the many ways the 405(d) Program can support you and your organization’s mission of keeping patients safe!

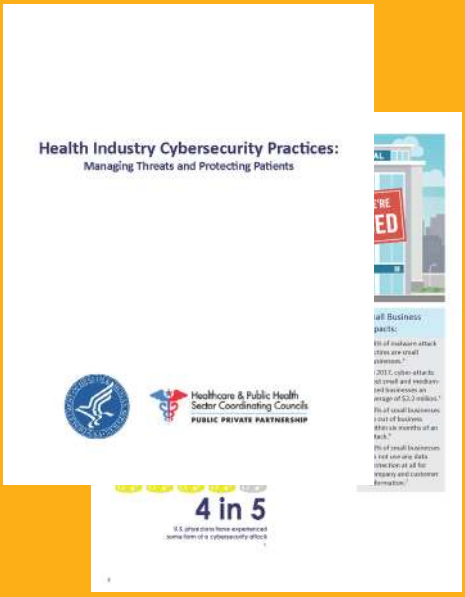
Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients Publication (HICP)—Check out the HICP Publication for an in-depth study into the top 5 threats facing the healthcare industry and the top ten mitigating practices you can implement RIGHT NOW to be cyber prepared. Click HERE to read.

405(d) SBARs—The 405(d) Situation, Background, Assessment, Recommendation (SBAR) is a HPH focused review of active cyber intelligence and alerts from across federal agencies. Mandated by the Cybersecurity Act of 2015 with the goal of aligning industry security approaches, the 405(d) SBARs are backed with the knowledge and expertise of HHS and the 405(d) Task Group. It provides the HPH sector with clear recommended mitigations based on 405(d)’s Health Industry Cybersecurity Practices publication, that healthcare organizations can apply against these current cyber vulnerabilities. Check out our newest on the Kaseya VSA Supply Chain Ransomware Attack HERE.

405(d) Awareness Materials—Looking for quick awareness materials to keep cybersecurity at the forefront of your employees’ and co-workers’ minds? Look no further than the 405(d) Social Media accounts on LinkedIn, Facebook, Twitter, and Instagram at **@ask405d**. We provide posters, quick tips, and statistics to help keep you engaged in all things cyber and also provide continued refreshers on cyber hygiene. Encourage your staff and co-workers to follow us so that cyber preparedness is always front and center!

405(d) Guest Webinars—Does your organization have a standing webinar series that is missing a cybersecurity element? The 405(d) Program will come to you! The 405(d) Program will curate a webinar specifically for your organization’s cybersecurity needs and invite other federal partners where appropriate to help educate and inform your workforce on cybersecurity issues.

We hope that you join us on social media to celebrate National Preparedness Month and always remember that cyber disasters are just as devastating as other disasters, threats, and hazards, therefore it is always best to be prepared because **cyber safety is patient safety!**



HICP

Kaseya SBAR

Stay tuned this fall to see new infographics developed by the 405(d) Program!

405(d) Chronicles

Security Awareness Program: Case Study

By Tom Carey, 405(d) Task Group Member

The 405(d) Chronicles is a platform for sharing firsthand insight, lessons learned, and perspectives from cybersecurity professionals in the field today.

Background

According to security researchers at IBM and the Cyber Security Intelligence Index, **95% of data breaches are caused by humans.** With this in mind it is important that organizations invest in security awareness training to help manage human error risk.

Traditional one-size-fits-all approaches to security awareness often lead to tepid and unquantifiable results. A strategy we have used at my company is a security awareness program that takes a two-pronged approach: **track, monitor, and tailor training content** and **engage and reinforce good cyber hygiene.**

This platform is designed to help understand team member cybersecurity risk over time and to positively engage team members focused on improving security habits. The program consists of:

- **Simplified dashboards** with insights about team members' collective and individual security risk over time
- **Individual security progress reports** shared with each team member for them to understand their unique security posture and provide examples on how to improve:
  - **measurement behaviors—**annual security training, phish simulations, malware events, password strength
  - **positive behaviors (e.g., extra credit)—**real world phish submissions, optional training completions
- **Tailored and personalized training** for each team member-based insights and tendencies

Track, Monitor, and Tailor Training Content

- Monitor prioritized human security behaviors
- Measure and track strengths and pain points
- Provide individualized reporting
- Iterate and expand datapoints

Engage and Reinforce Good Cyber Hygiene

- Incorporate micro-training sessions monthly
- Distribute the key learnings through multiple channels
  - Learning Management System
  - Internal web posts
  - Regular corporate communications
- Iterate through content monitoring engagement

The Results

The platform empowers the organization's security with the insights and reporting needed to maintain program efficacy at scale while also building trust among team members.

Based on the insights, learning, and opportunities identified via the platform, security awareness training and content is communicated to internal team members in micro-segments via multiple communication channels. Instead of relying on the more traditional annual lectures, migrating from topic to topic over multiple hours, HealthEquity integrates micro-training into its security awareness program providing bite-sized chunks of content on relevant security themes. This format allows for content based on real-life cybersecurity scenarios that our team members found engaging and consumable.

The combination of these tools increases engagement across the team member-base, while providing insight to leadership on positive trends in cyber security habits and identifying areas for improvement. This data and tooling have allowed us to:

- Tailor our trainings and education to match emerging security risks
- Further reinforce good cyber security habits into company culture
- Further reduce susceptibility to cyber threats

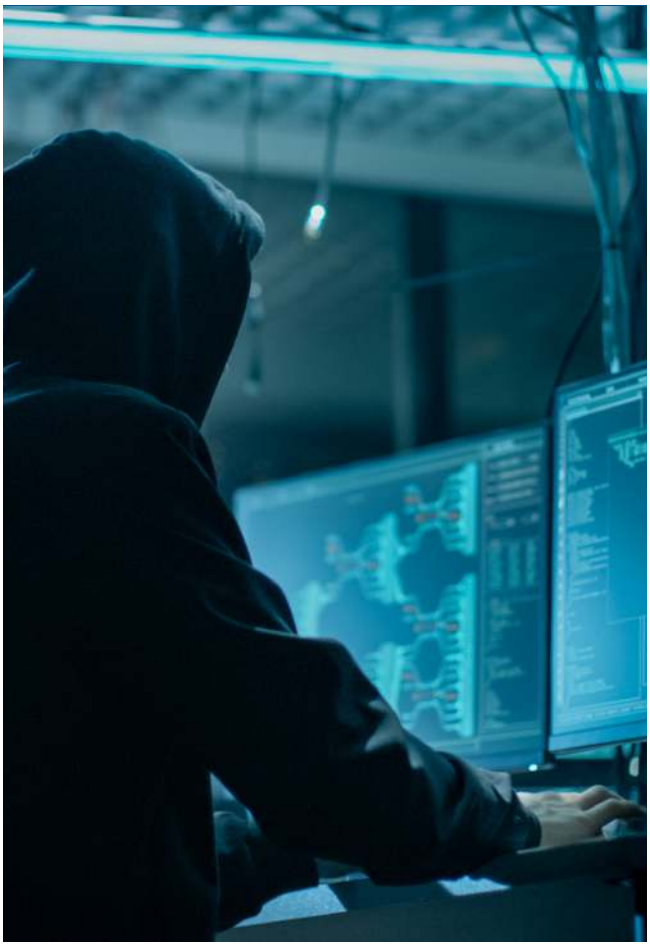
Happening Around Us

Hospitals lag other companies in cybersecurity risk ratings

A study published this week in the Journal of the American Medical Informatics Association found that hospitals with low cybersecurity ratings were more likely to experience a data breach. The research, which also compared hospital cybersecurity ratings with Fortune 1000 firms, found that health systems remain statistically more vulnerable to botnets, spam and malware. “Recent hacking and ransomware attacks may be shifting the security landscape for hospitals, with much larger potential hospital and patient consequences,” wrote University of Central Florida’s Sung Choi and Vanderbilt University’s M. Eric Johnson in the study. “Ongoing risk assessment is needed to keep up with these threats and will likely require even further security investment,” they added.

Learn how to protect your patients and organization from data breaches with the *Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients* publication.

Click here to read the full story from HealthcareITNews.



Eskenazi Health diverting ambulances as cyber-attack investigation continues

Companywide email and online medical record keeping are all a part of the self-imposed network shutdown at Eskenazi Health. Eskenazi Spokesperson Tom Surber said they decided to shut down their network after detecting an attempted ransomware attack the morning of Wednesday, August 4. Since then, any ambulances that would have headed toward the Eskenazi emergency room are now being diverted to other hospitals. Mitchell Parker, the Executive Director and Chief Information Security Director at IU Health, said these attacks can affect far more than private records. He said it also affects the way the hospital operates. In Eskenazi’s case, it is having to divert ambulances. “It has a cascading effect and what ends up happening is you increase the capacity at every other hospital in the radius that has an emergency room,” Parker said.

Learn how to protect your patients and organization from data breaches with the Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients publication.

Click here to read the full story from WXIN-Fox59.

Sanford Health target of attempted cyber attack

Sanford Health sustained an attempted "cyber security incident" and is working to contain its impact, the health care provider's top executive said Wednesday, Aug. 4. "Sanford Health has experienced an attempted cyber security incident, and we are taking aggressive measures to contain the impact," Sanford president and CEO Bill Gassen said in a statement. "Providing patients with exceptional care is our top priority, and we are doing everything possible to minimize disruption." Sanford's primary service area covers North Dakota, South Dakota and Minnesota. The health system has 46 hospitals, 224 clinics, 233 senior living communities, 158 skilled nursing and rehabilitation facilities and 47,757 employees.

Learn how to protect your patients and organization from data breaches with the Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients publication.

Click here to read the full story from Park Rapids Enterprise.

Other Federal Resources

CISA

- Stop Ransomware
- Get Your Stuff Off Search
- CDM Success Stories: Department of Health and Human Services (HHS)

HC3

- Qbot and Ransomware
- PwnedPiper Impact on Healthcare
- HiveNightmare/SeriousSAM Potential HPH Impact
- Top Routinely Exploited Vulnerabilities of 2020 and 2021

Upcoming Events

October is National Cybersecurity Awareness Month! Stay tuned for awareness materials and a special Spotlight Webinar from the 405(d) program!

Follow us!

Facebook
Instagram
Twitter
LinkedIn

Check out our website at 405d.hhs.gov!

About The 405(d) Post

This newsletter is for information purposes only and aims to broaden awareness and align healthcare security approaches. The news articles represented in this newsletter are chosen at random to foster awareness and are not in promotion of any news organization. The "A Word from the Task Group" and the "405(d) Chronicles" is written by a different 405(d) Task Group Member each issue and does not reflect the views of HHS as a whole. All Task Group Members have been invited to contribute to this newsletter.

Need To Contact Us? Email us at cisa405d@hhs.gov